

Technical Assessment: OWASP Juice Shop API & Auth Security

Assessor: Moe Htet Ar Kar (Phoe Cho) **Date:** July 2026

1. Vulnerability Identified

- **Authentication Bypass** via SQL Injection (CWE-89)
- **Broken Object Level Authorization (BOLA/IDOR)** in Basket API (CWE-639)

2. Proof of Concept (PoC)

- **Auth Bypass:** Intercepted `/rest/user/login` and injected `admin@juice-sh.op'--` in the email field. The database evaluated the comment operator `--`, bypassed password verification, and granted Admin access.
- **BOLA/IDOR:** Authenticated as a low-privilege user and changed the API parameter from `/rest/basket/5` to `/rest/basket/4` in Burp Suite, successfully viewing other users' shopping carts.

3. Impact

Attackers can hijack administrative accounts without passwords and leak private customer data horizontally.

4. Remediation

- Implement **Parameterized Queries (Prepared Statements)** to stop SQLi.
- Enforce **Server-Side Authorization Checks** to ensure users can only access their own basket ID.
- Replace sequential integer IDs with **UUIDs**.